

IT SECURITY POLICY

Modernized & Comprehensive Edition

Version	2.0
Effective Date	03 August 2026
Approved By	Cyber Crisis Management Group (CCMG), IIT Kharagpur
Next Review	Annually or as and when required
Custodian	Computer and Informatics Centre (CIC)

Aligned with: CERT-In Directions | IT Act 2000 | DPDP Act 2023 | ISO 27001:2022 | NIST CSF | CIS Controls v8

GLOSSARY OF TERMS AND ABBREVIATIONS

Key Terms

Term	Definition
Web	World Wide Web – the subset of the Internet accessible via a web browser
System	A platform combining hardware and software designed to run software programs
Network	A collection of computers, servers, and devices connected to communicate and share data
Campus	All academic, residential, hostel, and other areas owned or operated by IIT Kharagpur
IIT Community	Permanent and temporary employees, students, campus residents, authorized guests, visitors, and external agencies authorized to access campus IT resources
Data	Information stored, processed, or transmitted by a computer system
Public IP	An IP address directly accessible over the Internet
Port	A logical construct identifying a specific process or network service within a transport protocol
Log	A file containing records of activities or transactions of a system
Incident	Any event that threatens or compromises the confidentiality, integrity, or availability of IT systems or data
BYOD	Bring Your Own Device – use of personally owned devices on the Institute network
IoT	Internet of Things – smart/connected devices such as sensors, TVs, smart appliances
Zero Trust	A security model based on the principle of never trusting, always verifying access requests
MFA	Multi-Factor Authentication – use of two or more verification factors to authenticate a user
Vulnerability	A weakness in a system that can be exploited to gain unauthorized access or cause harm
VAPT	Vulnerability Assessment and Penetration Testing
SIEM	Security Information and Event Management – centralized security log analysis
EDR/XDR	Endpoint/Extended Detection and Response – advanced endpoint threat detection tools

Abbreviations

Abbreviation	Full Form
IIT	Indian Institute of Technology
IT	Information Technology
CIC	Computer and Informatics Centre
CISO	Chief Information Security Officer
CERT-In	Computer Emergency Response Team – India
DPDP	Digital Personal Data Protection (Act)
LAN / VLAN	Local Area Network / Virtual Local Area Network
VPN	Virtual Private Network
MFA	Multi-Factor Authentication
SMTP / SPF / DKIM / DMARC	Email delivery and authentication protocols
GPON	Gigabit Passive Optic Network
ERP	Enterprise Resource Planning
IoT	Internet of Things
CCTV	Closed Circuit Television
ISP	Internet Service Provider
VAPT	Vulnerability Assessment and Penetration Testing
SOC / SIEM	Security Operations Centre / Security Information and Event Management
RCA	Root Cause Analysis
SaaS	Software as a Service
CCMG	Cyber Crisis Management Group

The contact details of CISO and Deputy CISO

CISO	ciso@iitkgp.ac.in
Deputy CISO	dciso@iitkgp.ac.in

1. PREAMBLE

Indian Institute of Technology Kharagpur (IIT Kharagpur) is a large, residential, and research-intensive academic campus with a diverse and complex digital infrastructure that supports teaching, research, administration, innovation, industry collaboration, student activities, and residential services. This policy establishes the minimum cybersecurity requirements applicable across the Institute. All members of the IIT Community share the responsibility of understanding and complying with it. The policy is a public document and is available on the Institute and CIC websites.

Attacks and security incidents constitute a risk to the academic mission of the institute. The loss or corruption of data or unauthorized disclosure of information from research and instructional computers, student records, and financial systems could greatly hinder the legitimate activities of Institute faculty, staff, and students. The Institute also has a responsibility to reasonably secure its campus network and IT resources from misuse. Failure to exercise due diligence may lead to liability for damage done by persons accessing the network facility from or through the institute.

Like many other organizations, IIT Kharagpur has experienced a variety of security incidents of varying severity. Management of these incidents is the collective responsibility of the institute community. Failure to meet that responsibility could result in a tarnished reputation and also a potential liability.

The purpose of this policy is to establish guidelines, procedures, and requirements to ensure appropriate protection of the campus network and IT resources of the institute. The policy is intended to protect the integrity of campus network and IT resources of IIT Kharagpur and to mitigate the risks and losses associated with security threats to campus network and IT resources. In doing so, this policy also addresses the issues of confidentiality and integrity of personal and institute information.

The approved IT Security Policy is to be a public document, and IIT community should be made aware of the policy and the requirement to abide by it. Failure to abide by any part of the security policy by a user may result in restrictions placed on the user's access to the campus network and IT resources as decided by the competent authority of the institute. The user will also be solely responsible and liable for any legal actions or any other implications arising out of failure to comply with any part of this policy.

2. OBJECTIVES

This policy aims to:

- Protect the confidentiality, integrity, and availability of all institutional information assets.
- Ensure the secure and reliable operation of the Institute network, systems, and digital services.
- Reduce risks arising from cyberattacks, insider threats, malware, ransomware, and unauthorized access.
- Enable secure academic, research, and administrative operations across campus.
- Establish clear governance, accountability, and responsibilities for cybersecurity.
- Ensure compliance with CERT-In Directions, IT Act 2000, DPDP Act 2023, and applicable regulatory obligations.
- Promote a culture of cybersecurity awareness and shared responsibility among all users.
- Establish a structured incident response and cyber resilience framework.
- Provide clear, flexible, and reasonable policies for website hosting, software licensing, IoT, BYOD, research computing, intranet and internet connectivity, and cloud usage.

3. SCOPE

3.1 Who This Policy Applies To

This policy applies to all members of the IIT Community including:

- Faculty members (permanent and visiting)
- Students (undergraduate, postgraduate, doctoral, visiting students)
- Staff members (permanent and temporary/contractual)
- Researchers and postdoctoral fellows
- Authorized guests, collaborators, and visiting scholars
- Vendors, contractors, and third-party service providers with access to Institute's network and IT systems
- Alumni with authorized access
- Residents of campus quarters and hostels
- Extension centres and guest houses of IIT Kharagpur in other cities

3.2 What This Policy Covers

The policy applies to all Institute-owned, Institute-administered, and personally owned devices connected to the Institute network, and covers:

- Campus LAN, Wi-Fi, security policy
- System security policy
- External resource access policy
- Data security policy
- Web access policy
- Email access policy
- Direct external access using public IP address policy
- Physical security policy
- IOT security policy
- Website hosting and security policy
- Bring your own device (BYOD) policy
- Research computing and laboratory policy
- Cloud security policy
- Software security policy
- Artificial intelligence (AI) and generative AI usage policy
- Security monitoring and log management policy
- Incident response policy
- Security assessment policy
- Backup and disaster recovery policy
- Third-party and vendor security policy
- Security awareness and training policy

3.3 Scope Limitations

Personal computers and devices not connected to the Institute network, and data stored or processed solely outside Institute systems, are not subject to this policy. However, if such devices connect to the Institute network, they become subject to this policy for the duration of that connection.

This policy is subject to periodic revision and re-evaluation by the Institute. All revisions shall be reviewed and approved by the competent authority.

4. GOVERNANCE STRUCTURE

4.1 Cyber Crisis Management Group (CCMG)

A Cyber Crisis Management Group comprising the designated institute officials from the administration, CISO/ DCISO the Security Section representative, and relevant Departmental representatives shall be constituted to manage significant cybersecurity incidents and crises. The Director of the institute or their representative shall be the chairman of the committee.

This committee will function as an Information Security Governance Committee comprising representatives from CIC, Administration, Academic Departments, Research Units, Hostel Administration, Security Section, and Legal/Compliance. The committee shall:

- Review cybersecurity risks and the overall security posture of the Institute;
- Approve and update security policies;
- Monitor compliance and review significant incidents;
- Recommend improvements and oversee the implementation roadmap.

4.2 Chief Information Security Officer (CISO) / Deputy Chief Information Security Officer (DCISO)

The Institute shall designate a CISO and optionally, a Deputy CISO. Responsibilities include:

- Cybersecurity governance and day-to-day oversight;
- Incident coordination and CERT-In liaison;
- Security monitoring and policy implementation;
- Risk management and VAPT coordination
- Security awareness program oversight.

4.3 Institute Digital Task Force (IDTF)

The Institute Digital Task Force is constituted for technical review, enterprise architecture, digital governance and technology standardization for Institute-wide digital initiatives. The broad responsibilities of the Institute Digital Task Force shall include:

- Review proposals relating to development, procurement, customization, implementation and enhancement of institutional digital systems.
- Promote standardization, interoperability and integration across Institute digital platforms.
- Recommend enterprise architecture, authentication, cybersecurity and technology standards.
- Maintain an Institute-wide inventory of digital systems and monitor major digital initiatives.
- Constitute and coordinate functional verticals and working groups, as required

The Institute Digital Task Force shall function through the following broad functional verticals:

1. ERP, Enterprise Applications & Digital Integration.
2. IT Infrastructure, Network & Digital Services.
3. Web, Information & Communication.
4. Welfare & Health Digital Services.
5. Data Governance, Digital Policy & Compliance.

4.3 Departmental IT Representatives

Each department, school, centre, and administrative unit shall designate a Departmental IT Representative (or System Administrator) who acts as the local point of contact for IT security matters and coordinates with CIC. By default, the Head/Chairperson/Professor in Charge or

equivalent will act as the departmental IT representative, otherwise specified by the concerned department.

5. GENERAL ACCEPTABLE USE POLICY

Institute IT resources are provided for academic, research, and administrative activities of the IIT Kharagpur Community.

5.1 Permitted Use

Users may use Institute IT resources for:

- Academic teaching and learning activities;
- Research, experimentation, and scholarly work;
- Official administrative functions;
- Innovation, open-source development, and collaboration;
- Official communication and institute activities as approved by the competent authority of the institute.

5.2 Prohibited Activities

Users shall NOT:

- Engage in any illegal activity including unauthorized access, hacking, or cyberattacks on any internal or external system;
- Install or distribute pirated, unlicensed, or unauthorized software on Institute systems or systems connected to the Institute network. Users shall be solely liable for legal consequences arising from such use;
- Attempt to circumvent system security, guess others' passwords, forge account identities, or gain unauthorized access to accounts or network resources;
- Use Institute infrastructure for commercial cryptocurrency mining, unauthorized commercial gain, or private profit beyond what the competent authority of the Institute permits;
- Send harassing, threatening, offensive, abusive, or illegal communications over the Institute network;
- Display offensive material on Institute computing systems or through Institute digital channels;
- Distribute malware, ransomware, spyware, or any harmful code
- Conduct network scanning, probing, or research activities that may disrupt or compromise Institute or external systems without explicit written approval from the competent authority;
- Bypass or circumvent firewall policies, access controls, or any security measure using unauthorized tools including proxies, VPNs not provided by the Institute, or other circumvention tools;
- Share confidential credentials, passwords, or institutional access credentials with unauthorized persons;
- Upload sensitive institutional data, confidential research data, or personal data to AI platforms, cloud services, or external repositories;
- Use social media, web access, or external hosting in a manner that violates Indian laws or brings disrepute to the Institute. Users are solely responsible for content they post or transmit.
- Share sensitive institutional data (like personal information as classified under the DPDP Act 2023) over public domains intentionally or unintentionally (like through public Generative AI platforms like ChatGPT, Claude, etc.)

The Institute shall not be held responsible for the legal implications arising from a user's misuse of Institute IT resources. Violations may lead to access suspension, disciplinary action, or legal proceedings as appropriate.

5.3 User Responsibilities

- Each user is responsible for understanding and complying with this policy.
- Users must promptly report any suspected security incident, breach, or compromise to their system administrator, departmental IT representative, CISO/Deputy CISO, or CIC.
- Users aware of a breach must report it to the systems administrator or departmental representative responsible for security in that area without delay.
- Users are responsible for all activities conducted using their credentials.

6. SYSTEM SECURITY

These policies apply to all computer systems owned and/or administered by the Institute, and to individually owned systems connected to the Institute network.

6.1 System Administration

Every system (or group of related systems) connected to the Institute network shall have a designated system administrator or an authorized user fulfilling that role. For personal devices such as a faculty PC or student laptop, the owner acts as the system administrator. For shared resources (such as PC laboratories, servers, research laboratories having IT resources, etc.) under departments, schools, centers, or administrative units, the Head/Chairperson/Professor-in-Charge or equivalent of the relevant department, or a designated representative, shall act as the system administrator. A system administrator is responsible for:

- Identifying the set of users authorized to access the system
- Creating and managing separate user accounts with appropriate privileges for each authorized user
- Monitoring access, establishing user privileges, and performing necessary security actions;
- Taking reasonable precautions to safeguard against corruption, compromise, or destruction of data
- Preparing and maintaining backup and recovery plans for systems hosting critical data or services
- Maintaining the privacy of user data stored in the system
- Maintaining the privacy of academic/ project data stored in the system
- Ensuring all hardware and software license agreements are faithfully executed
- Keeping operating systems and applications current and applying all relevant security patches regularly
- Ensuring up-to-date anti-malware software is installed and updated regularly where applicable
- Ensuring that only authorized persons install applications on the system
- Ensuring that Security, Account, and System-level logging is turned on for all servers
- Ensuring that all personal storage devices (USB drives, diskettes, etc.) and downloaded files are scanned before use
- Ensuring that new systems are configured offline and are not connected to the network until they have reached an appropriate level of security.
- Ensuring that compromised systems are disconnected and sanitized offline and are not connected to the network until they have reached desired security level
- Ensuring that all IT, network and security advisories shared from time to time through the authoritative bodies recognized by the institute or the Government (such as CERT-IN or equivalent) are being followed up and responded back within the stipulated time.

6.2 User Account and Password Policy

User Accounts

- Each user shall have a unique user ID on every system like ERP, WiFi, Complaint Portals, and similar other service platforms supported by the institute. System administrators of the respective services shall be able to uniquely identify all users, including name, user ID, and associated information.
- Shared accounts should be avoided. If operationally necessary, they must be documented and monitored.
- Each user's profile and files must not be readable, writable, or executable by other unauthorized users. Access to shared resources shall be granted only as needed.
- Accounts created for temporary purposes (vendors, visitors, installations) must be deactivated after the designated period.
- Accounts shall be reviewed regularly to ensure only valid, active accounts remain. Dormant accounts shall be automatically disabled after a defined inactivity period.
- All user accounts, where possible, shall automatically have associated privileges revoked after a period of inactivity.
- Administrators and support staff must never request users to reveal their passwords, and must not disclose users' credentials to anyone.
- Users should be made aware about the DPDP Act 2023 and their responsibilities on the use of such online service platforms, and they should be governed by the applicable laws.

Passwords

- All accounts on the institute service platforms must have assigned passwords. Passwords shall be at least 8 characters long. The use of passphrases is encouraged and preferred over short, complex passwords.
- Passwords for privileged accounts shall be changed periodically. Mandatory periodic password changes for general users are not required unless a compromise is suspected.
- A password must be changed immediately if it is suspected or known to have been compromised.
- All vendor-supplied default passwords must be changed before any system is first used.
- Administrator passwords for critical systems such as mail, ERP, and servers shall be recorded and stored in a secure, access-controlled location.
- Immediately changing all relevant passwords whenever system security is suspected or known to be compromised or user resigned or after student leaved after completion of studies
- A password of any account should not be stored in institute mail/ personal mail and should not be forwarded to someone else
- Password should not be shared with any other personal

6.3 Multi-Factor Authentication (MFA)

MFA shall be used for access to the following systems:

- VPN access (for remote access to Institute network)
- Administrative accounts with privileged access
- Email systems
- ERP and academic management systems
- Remote administrative access (SSH, RDP, etc.) to servers

The Institute may gradually expand MFA coverage to additional systems based on risk assessment. Where MFA is impractical, risk-based compensating controls may be approved by the CISO or any other competent authority of the institute.

6.4 Endpoint Security

- All Institute-owned servers and workstations shall have up-to-date endpoint protection (anti-malware) software installed.
- The Institute shall progressively deploy Endpoint Detection and Response (EDR) solutions on critical systems.
- Operating systems and applications shall be kept updated with the latest security patches.
- All personal storage devices (USB drives, pen drives, diskettes, etc.) and downloaded files shall be scanned before use.
- Users should avoid connecting untrusted external storage devices to Institute systems.

6.5 Desktop/Laptop Security

- The system administrators should ensure that all office /academic Institute systems are installed with a genuine copy of the operating system and other application software solutions. Pirated or unsupported OS/software shall not be installed on official/academic Institute systems.
- Each department shall maintain a whitelist of authorized Applications/software's, which can be used by the users. Applications/Software's which are not part of the authorized list shall not be allowed.
- Enable disk encryption policy on laptop/mobile devices, if possible
- Enable standard user (non-administrator) accounts for all users on all official/academic Institute systems used for regular work. Admin access shall be given to limited users on requirement with approval of competent authority. For day-to-day work / operations use standard user account / privileges and use the admin privilege only for specific tasks wherever applicable. Disable Guest user on all office systems.
- Do not install Tor browsers or such anonymizer plug-ins for standard web-browsers.
- Avoid using Open Proxies, Free 3rd party VPN services for remote access.
- Do not allow peer-to-peer file sharing application to be installed on systems or to communicate with outside internet.
- Ensure that the system level firewall is configured properly.
- Remote-desktop applications (such as AnyDesk and TeamViewer) shall not be installed or used on critical systems, except with the explicit prior permission of the competent authority and subject to appropriate security controls and monitoring. Such permission may be granted on a case-by-case basis, depending on the specific operational need. Enable system level user password policy (password complexity & password expiry)
- Disable Remote Desktop (RDP), SMB, PowerShell and any other services, if not required by specific reason
- Offline backups with encryption for critical systems should be maintained. Online backup systems should be properly hardened and access to its network should be strictly restricted. Sensitive information or data should be stored in encrypted format.
- An inventory of all devices and systems connected to the network should be maintained with a focus on keeping track of versions of operating system and other software running on these devices and systems.
- It is recommended to keep all the systems which contain sensitive data/information disconnected from the internet/untrusted networks. In case such systems need to be connected to the Internet, explicit strong security measures and access control policies need to be enforced to ensure the data does not get visible to unauthorized/unauthenticated users.

6.6 REMOVABLE MEDIA SECURITY

- Perform a low format of the removable media before the first-time usage.
- Perform a secure wipe to delete the contents of the removable media.
- Scan the removable media with Antivirus software before accessing it.
- Encrypt the files /folders on the removable media.
- Always protect your documents with a strong password.
- Don't plug-in the removable media on any unauthorized devices.

6.7 SERVER SECURITY

- Any workstation, hardware server, or computer running a server application accessible to other users on the network falls under the purview of this server security policy.
- Ensure that the access to the server is restricted and appropriate security and access control solutions are deployed as recommended by NIC/CERT-IN and OEMs. Server level firewall may be configured.
- Ensure that servers are accessed through VPN for the purpose of administration and/or configuration.
- Ensure that groups and users are configured as per their role and responsibilities.
- Ensure that default user accounts are disabled.
- Configure DNS Server IP as recommended by the institute in the server DNS Settings. The public DNS setups (such as 8.8.8.8 or 8.8.8.4 DNS IPs) are strictly prohibited on servers (as well as on official computers).
- Disable remote access using root credential
- Configure institute's NTP Service in the server NTP settings for time synchronization.
- Ensure that the logs of servers are reviewed on a daily basis. Any suspicious activity related to user access, privilege escalation, authentications should be shared with the CISO/Deputy CISO.
- Ensure that all server logs are retained on a separate server.
- Ensure that unwanted or unused OS components, services, ports, applications are uninstalled or disabled.
- It is advisable to install the enterprise Antivirus/EDR client recommended by NIC/CERT-In on all servers.
- Remote-desktop software (like Anydesk, teamviewer, etc.) are not allowed in server
- It is recommended to create a staging environment for testing feature releases or testing update/patch of OS, BIOS firmware, application to ensure that the functionality of the server is not impacted by the changes/updates. Any constraint on part of applying an update/patch needs to be brought into the notice of CISO / Dy. CISO

6.8 Security measures for Printers, commonly used & shared devices in network

- Disable default credentials on printers
- Change default credentials for wireless on printers or disable wireless if not used.
- Disable default services (i.e. FTP, HTTP, SSH, SMB, Telnet etc.) on printers, if not in use. Enable security if using any of these services for managing printer remotely
- Restrict internet access for all printers, cloud-printing etc., enable Stricter User Access Controls
- Ensure remote administration of printers with secure connection (HTTPS) only with strong admin credentials. Printer administration shall only be allowed from the local network only.
- Ensure printer firmware is updated to the latest available from OEM. Firmware update/upgrade/patch shall only be downloaded from OEM website
- Ensure requirement of user passcodes in case of shared printers. Don't Allow printer to store print history
- Configure NTP on printer, enable logs and monitor.

6.9 Backup Policies

- The system administrator must evaluate the need for backups based on the nature of applications, services, and data hosted. Frequency and storage location shall be decided based on a risk analysis and data criticality.
- Systems with backup provisions shall be restorable within a reasonable period following data loss or compromise.
- Backup media and restoration processes must be tested periodically to verify effectiveness.
- Critical systems shall implement offline or immutable backup copies as a ransomware resilience measure where feasible.

7. NETWORK SECURITY POLICIES

These policies apply to all active and passive network components including switches, routers, access points, fibres, wired and wireless networks, and network endpoints.

7.1 Wire Network

- All network components within the institute are to be installed and managed by the Computer and Informatics Center (CIC), except for any network extensions made independently by faculty or staff members in residential quarters officially assigned to them by the institute.
- Isolated from the institute network, network components may be installed and administered by department/center/schools for special projects and/or teaching needs.
- Network components connected to the institute network may be installed and managed by departments, centers, or schools for specific projects and/or teaching requirements, provided that explicit written permission is obtained from CIC.
- All departments, schools, centers, or administrative/student bodies, as well as any other entities that have network components installed on their premises, are required to implement reasonable and appropriate measures to ensure the physical safety of these components
- All departments, schools, centers, or administrative/student bodies, or any other entities that have network endpoints installed on their premises must take reasonable and appropriate measures to guarantee that only authorized users can access the institute network through these network endpoints.
- Any change in the network installed and administered by CIC should be done by CIC or by CIC-authorized personnel in consultation with CIC.
- Each managed switch/router must have a designated network administrator or a group of network administrators from CIC who will manage the switch/router. The administrator(s) is responsible for:
 - Ensuring that only authorized personnel can access and configure the switch/router.
 - Ensuring that all applicable security patches are installed regularly.
 - Ensuring that if there is cause to believe that the switch/router is compromised, the issue is immediately reported to the appropriate higher authorities in CIC and action is taken to isolate the switch/router from the institute network if possible.
- Computing or network devices within the Institute campus (owned by any department/section), and connected to the campus network, if declared end of support by the corresponding OEM, will be upgraded by the Institute at best effort basis to avoid any security risk arising out of it.

7.2 Wireless Network

- Access to the Institute wireless network shall be authenticated to ensure only authorized users connect.
- Sensitive applications must not be hosted on wireless subnets without adequate encryption.
- Sensitive data must not be transmitted over the wireless network without adequate protection via encryption.
- Setting up personal unsecured (open, unauthenticated) / Secure wireless systems in academic areas and hostels is restricted and requires explicit approval from CIC.

- In residential areas, users may connect personal wireless devices to the Institute network equipment, subject to adhering to this IT security policy. Users must disconnect their personal wireless device from the Institute network while connecting to any other ISP.

8. EXTERNAL NETWORK ACCESS POLICY

This section governs all access to resources on the Internet from within IIT Kharagpur, and all access to the campus network from outside IIT Kharagpur.

8.1 Firewall and Perimeter Security

- All access via any protocol between the Institute network and the Internet must pass through a properly configured firewall centrally located in CIC.
- The Institute will allow specific ports and services through the firewall for general users. Any specific requirement due to academic, research, administrative, or technical activity shall be treated as an exception and forwarded through Departmental Heads/Deans to the Head, CIC for approval.
- The Institute firewall may block additional IPs/ports/services if advised by the Institute authority, government agencies, ISPs, or CERT-In for security or administrative reasons.
- Real-time traffic logs of incoming and outgoing connections passing through the firewall shall be maintained for a minimum period of 180 days, consistent with CERT-In requirements.
- CIC will be the custodian of firewall logs. Any request for sharing logs from any internal or external person or agency must be approved by the competent authority of the institute (Director or their representative).
- The firewall of the Institute will integrate intrusion prevention/protection system (IPS) technology to identify and attempt to thwart exploits.
- The firewall shall authenticate all users accessing the Internet from the Institute network. Any exception shall require approval of the competent authority.

8.2 VPN Access

- Authorized remote users accessing Institute systems from external networks shall use VPN or other secure remote access software approved by the Head, CIC.
- The Institute shall maintain a sufficient number of VPN licenses for faculty, staff, and students with justified requirements. VPN access shall be provided on recommendation by the respective departmental head and the approval from the Head, CIC for a specific period (which is not more than one year or until the user is a member of the IIT Kharagpur community, whichever is earlier).
- MFA shall be mandatory for VPN access.

8.3 External Campuses and Entities

- All external campuses of IIT Kharagpur in other cities may be connected to the internal network and shall be treated as an extension of the Institute network as directed by the competent authority of the institute.
- Section 8 companies and similar entities related to the Institute shall not be directly connected to the Institute LAN. Where necessary, they shall connect through the Institute firewall, with appropriate permissions granted by the competent authority of the institute.

8.4 Other ISP Connections

It is strictly prohibited to connect other/separate wire /wireless ISP networks (not obtained through CIC), to the Institute network in campus without explicit consent from the competent authority of the institute. When permitted for research or operational needs, the facility in-charge (preferably a permanent faculty of the institute) shall be responsible and ensure that the external network is firewalled from the research network for both inward and outward connections and should be separated/ isolated from institute network.

8.5 Live Streaming

Requests for live streaming of events inside the Institute over the campus network for access from within and outside the Institute shall be allowed when a written request is forwarded to Head, CIC approved by the competent authority of the institute. In general, live streaming shall be restricted through the firewall.

9. DATA SECURITY AND PRIVACY

9.1 Data Classification

All Institute data shall be classified into the following categories to ensure appropriate protection:

Classification	Description	Examples
Public	Information intended for unrestricted public access	Institute website content, published research, public notices
Internal	Information for use within the Institute community	Internal circulars, intranet content, department announcements
Confidential	Sensitive institutional or personal information requiring protection	Student records, HR data, financial records, exam papers
Restricted	Highly sensitive information with legal, regulatory, or contractual protection requirements	Personal data under DPDP Act, research contracts, legal documents

9.2 Data Protection Requirements

- Confidential data stored electronically must be protected with strong passwords and stored on secured servers / preferable offline (prevent from ransomware) storage to guard against loss, theft, unauthorized access, and unauthorized disclosure.
- Confidential data transmitted over a data network must always be protected using a secure connection method such as VPN or SSH/TLS.
- Confidential data shall not be disclosed to parties without explicit management authorization and then only on a need-to-know basis.
- No systems on wireless subnets shall store or transmit data of a sensitive nature such as credit card numbers, private student information, legal or attorney-privileged data without adequate protection via encryption.
- Confidential data must be securely destroyed when no longer needed.
- Sensitive institutional data, confidential research data, or personal data under the DPDP Act 2023 should not be uploaded to unapproved AI platforms, public cloud services, or external repositories without explicit permission from the competent authority of the institute.
- Any personal data collected or stored for the purpose of institute services/research/administration/teaching or any other purposes should be governed by the DPDP Act 2023 or its latest amendments.

9.3 Privacy Policy

The Institute recognizes the privacy expectations of its community members and is committed to complying with the DPDP Act 2023 and its subsequent amendments. The following principles apply:

- Email and other personal computer files, data, and accounts of faculty, staff, and students are in their personal domain. It is the Institute's policy to respect the privacy of such accounts.

- The Institute, as the owner of IT resources provided for academic and administrative purposes, reserves the right to access personal accounts of users with the approval of the competent authority (Director/Deputy Director/Registrar or their representatives) in the following circumstances:
 - By order of a judicial or competent law enforcement authority;
 - On the basis of a complaint alleging improper use of an account for activities such as spamming, harassment, distribution of illegal content, or other violations of this policy;
 - On reasonable suspicion supported by evidence such as download logs that the account stores or disseminates illegal material, pirated content, hate material, or pornography.
- The Institute shall appoint a Data Protection Officer (DPO) or equivalent as required under the DPDP Act 2023, responsible for ensuring compliance with data protection obligations.
- The Institute shall maintain a Register of Personal Data Processing activities for significant personal data processing operations.

10. WEB ACCESS

- All users connected to the Institute network will access web resources through the Institute firewall and will be subject to the web access policies implemented therein.
- The firewall shall have the facility to block access to malicious sites and sites with objectionable content. The list of sites to be blocked shall be decided using reputed URL filtering software, and may be updated from time to time. Head, CIC will be the authority for deciding which sites to block or allow. Consideration shall be given to ensuring that academic and research-related sites are not unnecessarily blocked.
- Irrespective of any list of blocked sites, users shall not attempt to access any website that is illegal under existing law. Users are solely responsible and liable for any legal consequences arising from illegal web access.
- Users shall not attempt to hack or tamper with any website not directly owned or administered by them. Users are solely responsible for any legal or other implication arising out of such activity.
- Users must not bypass the policies implemented in the firewall using any means including commercial or open source proxies or VPNs. Users are solely responsible and liable for any legal action or implication arising from such bypassing.

11. MAIL MESSAGING SECURITY

- All mail servers of the Institute shall have one or more designated administrators and shall follow all policies specified in the System Security Policies section.
- The mail administrator shall ensure that all incoming mails in the SMTP gateway are scanned for viruses before delivery to user mailboxes.
- Mass mailing inside the Institute mail-messaging system is restricted. Users are encouraged to use the internal notice board 'APNA' for broadcast communications. Mass mailing to group lists covering all faculty, all users, etc., may be done only by the designated officials as recommended and approved by the competent authority of the institute.
- Users shall not disclose confidential information such as e-mail, ERP, or system passwords in response to any email, phone call, or other communication. The Institute should never ask for passwords from users. Individual account holders are personally accountable for misuse of their accounts. Such confidential information should not be disclosed to any third party under any circumstances. For official role transfers (like Deans, Heads, Offices, etc.) and such role-based email IDs, the corresponding passwords should be changed immediately after the handover of the responsibilities.

- Users must avoid opening mail or attachments from unknown or suspicious sources without confirming their authenticity. Phishing awareness shall be included in the Institute's security awareness program.
- Any attempt by users to break into other users' email accounts is punishable. The punishment will be as deemed fit by the competent authority.
- All usage and account management of the mail messaging system shall be governed by the IT Policy of the Institute.
- Observe caution with documents containing macros while downloading attachments, always select the “disable macros” option and ensure that protected mode is enabled on your office productivity applications like MS Office.

12. DIRECT EXTERNAL ACCESS USING PUBLIC IP ADDRESSES

Most systems in the Institute use IP addresses from the private IP block. Public IP addresses are usually reserved for CIC use on Institute systems that need to be directly accessed from outside the Institute (e.g., web server). Machines with public IP addresses pose a security risk as they can be directly accessed from outside the Institute. The following policies shall govern the allocation of public IPs by CIC:

- Ensure that the Applications/websites/services are hosted only at the designated centres of Institute or Cloud Service providers empanelled by MeitY. No Internet facing application / website shall be hosted within the LAN segment of a Department/Office/Hostel/Residence.
- Public IP addresses shall be allocated only after very careful consideration of the actual need, and only in rare cases when no other option exists. Allocation of public IP shall be an exception, not a norm.
- Only systems that require direct external access shall be considered for public IP allocation.
- Wherever possible, applications and data requiring external access shall be hosted on a single system to minimise the number of systems with public IPs.
- Database for the application should not be in the same system.
- Any confidential /user privacy data should not be kept in the system
- Head, CIC is the authority for allocation of public IP addresses on case-to-case basis, based on the request from the concerned official duly forwarded by the Head/Chairperson/Dean of the respective units.
- Each machine assigned a public IP must have a designated system administrator or authorized person identified by the relevant faculty member or division head.
- Administrative access to the system should be through jump server or restrictive form trusted host
- The designated system administrator must ensure that:
 - The system is always updated with the latest security patches
 - The system should be hardened in accordance with OEM guidelines of the OS and the software/application that has been installed
 - A plan for regular VAPT of the system is in place
 - Logs (audit, application etc.) are maintained for a minimum of 90 days monitoring access to the machine.
 - Logs should be backup so that administrator can produce when compromised
- The system administrator must monitor the system regularly and disconnect it from the Institute network immediately and inform CIC if there is cause to believe the security of the system has been compromised.
- Wherever possible, preferably the system shall be physically located in CIC and placed in an appropriate security zone.
- The faculty member or head of the department/centre/school/section using the system is finally responsible for any security attacks originating from that system.

13. WEBSITE HOSTING AND SECURITY

This policy applies to all websites and web applications hosted under the *.iitkgp.ac.in domain, covering all hosting models including shared CIC infrastructure, departmental servers, and third-party cloud services.

13.1 Permissible Use

Websites must be used exclusively for Departments, Centres, Schools, Halls, Section 8 companies, Academic, Research, Outreach and Upskilling activities, Student and Employee welfare, or Employee bio-sketches, affiliated with IIT Kharagpur. Use for personal monetary gain, commercial advertising, or the display of offensive material is strictly prohibited. The user is solely liable for any legal implications arising from the website's content.

13.2 Stakeholder Validation

- In the event of a change in ownership (e.g., a PI or developer leaving), CIC must be notified immediately to update stakeholder records.
- CIC will perform periodic checks to validate that the listed stakeholders (PI, HOD, Sys Admin, etc.) of each website are still valid. If no response is received after 3 consecutive follow-ups, the website will be decommissioned.

13.3 Hosting and Security Standards

- **Domain and hosting location:** All websites under the *.iitkgp.ac.in domain must be hosted within the IIT Kharagpur network. Any website hosted outside the IIT Kharagpur network shall not be permitted to use the *.iitkgp.ac.in domain. Such websites should preferably be hosted within a dedicated DMZ setup located within the premises of the Computer and Informatics Centre (CIC). For websites hosted in this DMZ, CIC will carry out the annual security auditing and the necessary periodic penetration testing.
- **Websites hosted outside the CIC DMZ but within the network:** If a website administrator intends to host a *.iitkgp.ac.in website outside the dedicated DMZ but still within the IIT Kharagpur network, the administrator must submit a declaration to CIC. For such websites, the administrator is responsible for conducting security and quality auditing and for submitting the report to CIC. The first audit must be completed within three months of hosting. Thereafter, the website must undergo security and quality auditing once every year for as long as it remains live.
- **Security requirements applicable to all websites:** Irrespective of the place of physical hosting, all communication with a website must be exclusively over HTTPS, with SSL/TLS enabled. HTTP access shall not be permitted. Every website must also undergo penetration testing and security auditing by a CERT-In empanelled organization, annually and after any significant code or infrastructure change. Critical vulnerabilities must be patched within 24 to 48 hours. High and medium vulnerabilities must be resolved within 14 days. If the risk to the Institute network is deemed too high, CIC may remove the website from the network immediately, irrespective of these timelines.
- **Default passwords must be changed immediately.** The use of outdated or end-of-life software, frameworks, plugins, libraries, or platforms that no longer receive security patches is prohibited. MFA/2FA must be enabled for login wherever applicable. Websites developed on Institute infrastructure must follow secure coding practices, with reference to the OWASP Secure Coding Practices Quick Reference Guide and CERT-In whitepapers. Websites must also comply with the Guidelines for Indian Government Websites (GIGW) issued by MeitY, wherever applicable (<https://guidelines.india.gov.in/>).
- **Audit reports and oversight:** The CISO, DCISO, CIC, or CCMG may request the latest audit report at any time. If the website owner is unable to produce the report within the stipulated timeline, appropriate measures may be taken to protect Institute security. CIC also reserves the right to conduct independent security audits of websites and web applications

hosted on CIC shared servers or within CIC-managed infrastructure, and the findings shall be shared with website owners for remediation.

- **Monitoring, responsibility, and log retention:** Website owners must continuously monitor logs for anomalies. For a website hosted outside CIC-managed infrastructure but within the IIT Kharagpur network, the owner shall be solely responsible for system security, application security, and log retention for a minimum period of 90 days. For a website hosted on CIC shared servers, CIC shall be responsible for the system security of the web-hosting platform, such as the host operating system, but shall not be responsible for application-level vulnerabilities in the website.
- **Approved frameworks for CIC shared servers:** For websites hosted on CIC shared servers, owners must use only the frameworks explicitly approved and listed by CIC. Owners should consult the CIC web hosting team regularly to remain compliant with the most current hosting procedures, frameworks, and guidelines.
- **Incident handling:** If a website is compromised, CIC must be notified immediately, and the website shall be removed from the network or disabled until the issue is resolved. The website owner must submit a detailed Root Cause Analysis (RCA) report. CIC may conduct further investigation to prevent recurrence and to protect Institute infrastructure.
- **Event-specific websites:** An event-specific website under the *.iitkgp.ac.in domain should ideally remain live only up to three months after the completion of the event. If the administrator wishes to retain the website beyond this period, they must intimate CIC and continue to follow the annual security and quality auditing requirements for as long as the website remains live.
- **DPDP Compliance:** All websites hosted within the IIT Kharagpur network and under the domain *.iitkgp.ac.in should comply with the DPDP Act 2023 and its subsequent amendments.

13.4 Responsibility Matrix

Responsibility	CIC Server	Dept. Server at CIC	Dept./External Server
Server Maintenance (Hardware & Software)	CIC	PI / PIC / Website In-charge	PI / PIC / Website In-charge
Log Retention	CIC	PI / PIC / Website In-charge	PI / PIC / Website In-charge
Log Monitoring	PI / PIC / Website In-charge	PI / PIC / Website In-charge	PI / PIC / Website In-charge
Application Security	PI / PIC / Website In-charge	PI / PIC / Website In-charge	PI / PIC / Website In-charge
Penetration Testing	PI / PIC / Website In-charge	PI / PIC / Website In-charge	PI / PIC / Website In-charge

14. IoT AND SMART DEVICE SECURITY

This section pertains to all IoT and smart devices that are either connected to the Institute network or deployed independently, and they shall be utilized solely for research purposes.

- All IoT and smart devices shall be placed in a dedicated, segmented IoT LAN isolated from critical administrative and research systems.
- Access to and from any IIT campus network should be blocked/restricted for all IoT and smart devices.

- Required ports may be opened in the firewall for IoT and smart devices for Internet connectivity. Users are responsible for obtaining required port details from manufacturers or service providers. Exceptions to the restrictive default policy must be approved by Head, CIC on recommendation of the respective Head/Dean or other administrative official for the respective unit.
- Default passwords must NOT be used on IoT devices. Users must change default passwords and maintain strong login credentials for all IoT devices.
- Default setting must be modified with suitable required configurations.
- Device firmware and software updates must be applied regularly to eliminate known security vulnerabilities.
- Users must check available device features and disable any features not required for use, to reduce the device's attack surface.
- IoT devices suspected to be compromised or exhibiting anomalous behaviour must be immediately disconnected from the network and reported to CIC.
- CCTV deployed in any department or residence are prohibited from connection to IIT campus network, without explicit permission from the competent authority of the institute, which may be granted under special purposes only. However, as per the government guidelines, the CCTV network should be separate from the institute network.
- It is recommended to use IoT devices certified by the government (<https://www.stgc.gov.in/certified-product>). Certification is mandatory for CCTV cameras as per Para 4 of Circular issued by IPHW Division, MeitY vide No. W-18/26/2025-IPHW dated 04.02.2026.

15. PHYSICAL SECURITY OF IT INFRASTRUCTURE

- The Security Section of IIT Kharagpur will look after the physical security of the campus, including the entire IT infrastructure.
- All critical computing and network devices shall be kept in a place under lock and key or digital access control, or both. The respective departments or hostel authorities are responsible for these resources and shall report to the Security Section in case of any theft or eventuality.
- The Institute's digital surveillance (CCTV) system may monitor security aspects of critical computing and network items in the campus.
- The responsibility of GPON and other IT equipment in residential quarters provided by IIT Kharagpur rests with the residents. Any eventuality or theft must be reported to the Security Section and CIC.
- The responsibility of IT equipment such as PCs, Laptops, scanners, printers, and other IT-related devices provided by IIT Kharagpur to users for official use rests with the concerned users. Any eventuality or theft must be reported to the Security Section and the respective department/centre/school/section/unit.
- Access to data centres and server rooms shall be restricted to authorized personnel only. Visitor access shall be logged.
- Environmental controls (fire suppression, temperature/humidity monitoring, power backup) shall be maintained in all data centre and critical server room facilities.

16. BRING YOUR OWN DEVICE (BYOD)

IIT Kharagpur recognizes the widespread use of personally owned devices for academic, research, and communication activities. Personal devices may be connected to the Institute network subject to the following requirements:

16.1 Minimum Security Requirements for BYOD

- Devices must have up-to-date operating systems with current security patches;
- Devices must have active anti-malware or endpoint protection software;
- Devices must not have been 'jailbroken' or 'rooted' in a way that circumvents security controls;
- Devices must comply with the General Acceptable Use Policy when connected to the Institute network.

16.2 Network Access

- Personal devices should preferably be connected to the designated student/residential Wi-Fi or BYOD network rather than the administrative or research network.
- Personal devices in residential areas may connect to the Institute network equipment. Users must disconnect their personal device from the Institute network when connecting to any other ISP.
- The Institute reserves the right to quarantine or disconnect any personal device that is found to pose a security risk to the Institute network.

16.3 Data on Personal Devices

The Institute does not take responsibility for any loss of personal data on personally owned devices. Users should not store sensitive or classified Institute data on personal devices without adequate encryption and authorization.

17. RESEARCH COMPUTING AND LABORATORY

IIT Kharagpur recognizes that research environments have unique security requirements that may differ from standard administrative or academic systems. This section provides flexibility for research computing while maintaining baseline security standards.

17.1 Research Environment Flexibility

- Research environments may require customized security controls depending on the nature of research;
- Legacy scientific equipment that cannot be patched may be exempted from certain controls with documented risk acceptance;
- High-performance computing (HPC) systems may follow specialized security procedures approved by CIC;
- Research groups shall coordinate with CIC to identify and implement reasonable security controls appropriate to their environment.

17.2 High-Risk Research Environments

Research environments handling sensitive data (e.g., clinical data, defence-related research, industry-confidential research) may require:

- Network isolation or dedicated VLANs;
- Restricted Internet access during experiments;
- Additional monitoring and logging;
- Dedicated security review with CIC.

17.3 Research Network Experimentation

Any research and experimental activity on the Institute network that may hamper the operation of the network or compromise security of external or internal systems is not permitted without explicit written permission from the competent authority of the Institute. Research groups requiring network experimentation facilities shall request a dedicated isolated test network from CIC.

18. CLOUD SECURITY

18.1 Approved Cloud Services

The Institute may provide approved cloud-based services (e.g., Microsoft 365, Google Workspace, cloud-hosted ERP) to its community. Users shall use only Institute-provided or explicitly approved cloud services for sensitive academic and administrative work.

18.2 Prohibited Uses

- Sensitive institutional data, personal data under the DPDP Act, confidential research data, or financial data shall not be stored on unapproved personal cloud services (e.g., personal Google Drive, Dropbox, etc.) without authorization.
- Users shall not upload examination papers, student records, research contracts, or confidential institutional information to unapproved AI platforms or cloud services.

18.3 Access Security

- Access to Institute cloud services shall be protected by MFA.
- Users are responsible for maintaining the security of their institutional cloud credentials. If a compromise is detected, CIC reserves the right to revoke access.
- Users shall log out of cloud services on shared or public computers.

18.4 Vendor/SaaS Governance

CIC shall evaluate the security posture of significant cloud service providers and SaaS platforms used by the Institute and include appropriate data protection requirements in vendor agreements where applicable.

The users should follow Cloud Security Best Practices as published by Cloud Management Office (CMO) under Ministry of Electronics and Information Technology (MeitY) -- <https://egovstandards.gov.in/sites/default/files/2026-03/Cloud%20Security%20Best%20Practices.pdf>.

19. USE OF ONLINE COLLABORATIVE AND CLOUD-BASED PRODUCTIVITY PLATFORMS

Scope

This section governs the use of externally hosted online platforms that transmit, store, or process institute information on infrastructure owned or operated by a third party. This includes, but is not limited to, code hosting and version-control services (such as GitHub and GitLab), writing and language-assistance tools (such as Grammarly), document and file collaboration services (such as Google Workspace, Microsoft 365, Overleaf, and Dropbox), project-management and communication tools (such as Slack, Trello, and Notion), and any similar Software-as-a-Service platform. It applies to all faculty, staff, students, research scholars, project personnel, and any other person acting on behalf of the institute.

19.1 Guiding principle.

- The use of such platforms is permitted for legitimate academic, research, and administrative purposes, provided that the sensitivity of the information involved is matched to the protections offered by the platform.
- The person uploading or transmitting information remains responsible for ensuring that its disclosure to the platform provider is lawful, contractually permissible, and consistent with the IT security policy of the institute as well as the DPDP Act 2023 for sharing/uploading of personal data.

19.2 Data classification and permitted use.

- Information transmitted to any external platform shall be handled according to its classification under the data classification given in Clause 9.1 of this document.
 - Public or already-published information may be used freely on such platforms. Internal information may be used only on platforms approved under Clause 18.1, and only through institute-provided accounts.
 - Confidential and restricted information shall not be uploaded to, or processed by, any external platform except where the platform is explicitly approved for that classification and an appropriate agreement is in force.
- For the purpose of this clause, confidential and restricted information includes unpublished research data and manuscripts, grant and project proposals, examination papers, question banks, answer scripts, evaluation records, personal data of students and employees, financial records, and any material received under a confidentiality or non-disclosure obligation from a sponsor or collaborator.

19.3 Compliance with data protection and sponsor obligations.

- Where information constitutes personal data, its transmission to any external platform shall comply with applicable data protection law, including the DPDP Act, 2023, and the rules framed thereunder.
- Where information is governed by a sponsored-research agreement, funding condition, or contractual confidentiality clause, the more restrictive of that obligation and this policy shall apply.

19.4 Platform approval and vetting.

- The institute shall maintain a list of approved platforms and their permitted data classifications as given in Clause 9.1. A platform not on this list shall not be used for internal, confidential, or restricted information until it has been assessed and approved by the competent authority of the institute.
- Assessment shall consider, among other factors, the provider's security posture and certifications, the location in which data is stored, the provider's terms of service regarding ownership and reuse of uploaded content, and the availability of enterprise or institutional controls.

19.5 Account and access requirements.

- Where a platform is used for institute purposes, the user shall register using the official institute email address rather than a personal account, wherever the platform permits. Multi-factor authentication shall be enabled where available.
- Access credentials, tokens, and keys for these platforms shall not be shared, embedded in code, or stored in plain text.

19.6 Provisions for code hosting and version-control platforms.

- Source code, configuration, and related artifacts shall be published only after confirming that they contain no credentials, access tokens, API keys, passwords, private cryptographic material, personal data, or unpublished information whose disclosure has not been authorized.
- Repositories containing institute or sponsored-project code shall default to private visibility, and shall be made public only with the consent of the project lead and after confirming that no intellectual property, patentable material, or sponsor-restricted content would be prematurely disclosed.
- Where the platform offers an institutional or organization account, project repositories should be maintained under it rather than under individual personal accounts, so that access survives the departure of any individual.

19.7 Provisions for language-assistance, translation, and text-processing tools.

- Tools that transmit text to external servers for processing, including grammar-checking, translation, transcription, and writing-assistance services, shall not be used on confidential or restricted text.
- In particular, such tools shall not be applied to confidential information as classified by the respective unit of the institute, including but not limited to examination material, answer scripts, personnel or disciplinary records, or documents received under confidentiality obligations, since the full content is transmitted to, and may be retained by, the provider. Where these capabilities are required for sensitive material, only offline or institutionally approved tools shall be used.

19.8 Ownership and reuse of uploaded content.

Before adopting any platform for institute purposes, the user shall verify that the provider's terms do not claim ownership of, or an unrestricted right to reuse, uploaded content in a manner incompatible with the institute's or a sponsor's interests. Platforms that assert a right to use uploaded content for training, marketing, or redistribution shall not be used for confidential or restricted information.

19.9 Responsibility and enforcement.

Departments, centres, and administrative units shall ensure that personnel under their purview are aware of this section. When in doubt about whether a particular platform or use is permitted, the user shall seek clarification from the governing authority (like SRIC for project-related materials) before proceeding.

20. SOFTWARE LICENSING AND USAGE

Scope

This policy establishes the governance framework for all software procured by the CIC and by academic/administrative units of the Institute. Access to Institute-licensed resources is strictly limited to authorized students, faculty, staff, and registered guests.

20.1 Software Access Models

The Institute provides software through two primary delivery methods. Users must identify the type of software they are using to ensure compliance. The list of software and their respective access models is maintained on the CIC Portal.

Type A – On-Premise / Campus Licenses (e.g., Ansys, SolidWorks, MATLAB):

- The software must be used within the Campus Network or via IITKGP VPN;
- These utilize a central license server. Users should close applications when idle to release floating seats for others.

Type B – Cloud Subscriptions / SaaS (e.g., Adobe, Microsoft 365, Teams):

- These may be accessed via any public network using Institute-provided credentials;
- Users are responsible for maintaining the security of their institutional login. If any compromise is detected, CIC reserves the right to revoke the license.

20.2 Permissible Use and Academic Integrity

- Software is for teaching, learning, and non-commercial research only;
- Use of these licenses for personal financial gain, private consultancy, or developing commercial products is strictly prohibited;
- End users should verify that the software license aligns with the intended use;

- Additional approvals may be required for installation of specific restricted software. Users should consult the CIC website for the list of restricted applications and the approval protocol.
- Users must not share the license credentials with anyone else, inside or outside of IIT Kharagpur.

20.3 Prohibitions and Security Standards

- Using outdated End-of-Life (EOL) software that no longer receives security patches is strictly prohibited;
- No attempt shall be made to 'jailbreak', 'crack', or bypass the licensing mechanisms of any software;
- The use of unlicensed or pirated software on any device connected to the Institute network is a strict violation of this policy. Users shall be solely responsible and liable for any legal action or other implication arising from such use;
- Institute licenses are non-transferable and cannot be sold or shared with external parties.

20.4 Separation and Fair Usage Policy

Upon leaving the Institute (graduation, retirement, or resignation):

- Users are responsible for removing all Institute-licensed software from personal devices upon separation from the Institute;
- Users are responsible for informing CIC to deactivate Institute-licensed software upon separation or when they no longer need the software, to enable license re-assignment;
- CIC reserves the right to conduct periodic reviews of current active users and perform clean-up activities.

20.5 License Management

- For any educational, application, or other software procured for academic, administrative, and/or research purposes by the CIC, licenses will be managed by CIC using suitable license servers or otherwise to maintain a record of license distribution to the users.
- For any software procured by any academic or administrative unit of the Institute, the corresponding unit shall maintain a record of license distribution to the users.
- Individual users procuring software for research or personal use shall adhere to the Institute IT security policy if the software is used on a computer connected to the Institute network. Such software shall be procured and used with valid licenses.

21. ARTIFICIAL INTELLIGENCE (AI) AND GENERATIVE AI USAGE

The use of AI and Generative AI (GenAI) tools is increasingly common in academic, research, and administrative work. Users shall exercise caution when using AI platforms and adhere to the following guidelines:

- Sensitive institutional data, confidential research information, personal data under the DPDP Act 2023 or its amendments, examination papers, financial records, or legal documents shall not be uploaded to unapproved AI platforms or public GenAI services.
- AI-generated outputs used in academic, research, or administrative work must be appropriately reviewed, validated, and disclosed as per applicable academic integrity guidelines of the Institute.
- Users should be aware that prompts and data entered into public AI platforms may be used for model training by the service provider. Users shall exercise judgment about what information is safe to share.
- The use of AI tools to facilitate unauthorized access, circumvent security controls, generate malicious code, or conduct cyberattacks is strictly prohibited.

- The Institute may maintain a list of approved AI tools and platforms for common institutional use. Users are encouraged to use these approved tools for sensitive work.

22. SECURITY MONITORING AND LOG MANAGEMENT

22.1 Security Logging

The Institute shall maintain security logs for critical systems including firewalls, VPN systems, authentication systems, servers, administrative systems, and email platforms.

22.2 Log Retention

Security logs shall be retained for a minimum of 180 days, consistent with CERT-In Directions. Firewall and web access logs shall be maintained for a minimum of 180 days. Logs for specific systems may be retained for longer periods based on regulatory requirements or operational needs.

22.3 Time Synchronization

All critical systems shall synchronize with approved NTP (Network Time Protocol) time sources to ensure accurate and consistent log timestamps for forensic purposes.

22.4 Privacy in Monitoring

Monitoring activities shall be conducted in a manner that balances cybersecurity needs with the reasonable privacy expectations of the academic community. Monitoring shall be used for security purposes and not for general surveillance of academic or personal activity.

22.5 Security Operations

The Institute shall progressively develop security monitoring capabilities, including centralized log management (SIEM) and, over time, Security Operations Centre (SOC) capabilities, to improve threat detection and incident response times.

23 INCIDENT RESPONSE

23.1 Cyber Incident Response Team

The Institute shall maintain a Cyber Incident Response Team (CIRT) coordinated by CIC, comprising the CISO/Head CIC, CCMG members, system administrators, and relevant departmental representatives.

23.2 Incident Reporting

All users shall promptly report the following to CIC or their departmental IT representative:

- Malware or ransomware infections;
- Phishing attacks or social engineering attempts;
- Unauthorized access to systems or accounts;
- Suspected or confirmed data breaches;
- Suspicious network activity;
- Compromised credentials.
- Anything else that can potentially violate the IT Security Policy of the institute.

23.3 CERT-In Mandatory Reporting

Cyber incidents covered under CERT-In Directions shall be reported to CERT-In within the prescribed timelines (currently 6 hours for covered incidents). The designated CERT-In Nodal Officer shall be responsible for all regulatory reporting obligations.

23.4 Incident Handling

The Cyber Incident Response Team shall follow a structured incident response process including:

- Identification and initial triage of the incident;
- Containment to prevent further damage;
- Evidence preservation for forensic analysis;
- Investigation to determine root cause;
- Recovery and restoration of affected systems;
- Post-incident review and lessons learned.

23.5 Ransomware Resilience

The Institute shall implement reasonable safeguards against ransomware including regular backups, offline or immutable backups where feasible, endpoint protection, user awareness training, network segmentation, and periodic recovery testing.

24. SECURITY ASSESSMENT

- The critical IT resources of the Institute shall be protected from various security threats. The Institute may conduct periodic vulnerability assessments and penetration testing of critical IT resources and assets to minimize risks.
- The Institute may also conduct other security assessments of critical assets and their compliance with regulatory and technological requirements from time to time.
- Security assessment results shall be treated as confidential and shared only on a need-to-know basis with the CISO, CCMG, and relevant system owners.

25. BACKUP AND DISASTER RECOVERY

Critical systems and institutional data shall be backed up periodically. Backup procedures shall include secure storage, periodic restoration testing, and protection against unauthorized access.

- The system administrator of a system shall evaluate the need for backups based on the nature of applications, services, and data hosted. The frequency and storage location of backups shall be determined based on a risk analysis and the criticality of the data.
- Systems with backup provisions shall be restorable within a reasonable period after any failure due to loss of data or compromise.
- Backup media and restoration processes shall be tested periodically to determine their effectiveness.
- Critical Institute systems shall implement offline or immutable backup copies as a ransomware resilience measure where feasible.
- The Institute shall progressively establish disaster recovery procedures, business continuity planning, and recovery prioritization for critical services including ERP, email, and the Institute website.

26. SECURITY AWARENESS AND TRAINING POLICY

The Institute shall promote a culture of cybersecurity awareness through regular programs, advisories, phishing simulation campaigns, workshops, and training. While CIC will be organising security awareness initiatives, individual academic, research, and administrative bodies are also encouraged to run periodic training programs.

- All new users (students, staff, faculty) should receive basic security awareness orientation;
- Regular security advisories and updates shall be communicated to the Institute community via APNA or email;
- Phishing awareness and simulation campaigns may be conducted periodically;

- Specialized training may be provided to system administrators, developers, researchers, and administrative staff with elevated access and responsibilities;
- Security awareness content shall include guidance on password hygiene, phishing recognition, safe web browsing, data handling, and incident reporting.

27. THIRD-PARTY AND VENDOR SECURITY

- Third-party entities (vendors, contractors, consultants, service providers) accessing Institute systems shall follow applicable security requirements of this policy and shall use only authorized access mechanisms.
- Vendors provided with temporary access shall have accounts deactivated after the designated period of engagement.
- High-risk vendors or those with access to critical systems may be required to undergo a security assessment before being granted access.
- Vendors must not disclose, copy, or misuse any institutional data they encounter while performing their duties. Appropriate data protection clauses shall be included in vendor contracts.
- Section 8 companies and similar entities related to the Institute shall not be directly connected to the Institute LAN and shall access Institute resources only through the Institute firewall with explicit approval.

28. POLICY EXCEPTIONS

Recognizing the diversity of academic, research, and laboratory environments, justified exceptions to specific provisions of this policy may be granted for research requirements, legacy scientific systems, specialized laboratory environments, and academic experimentation needs.

All exceptions shall:

- Be documented with a clear justification;
- Be recommended by the respective Deans/Heads/Chairpersons/Professor-in-charge of the concerned unit following the internal policies of that unit (like routing through the Department's administrative committee or equivalent);
- Be assessed for risk by CIC;
- Require approval from Head, CIC and/or the competent authority;
- Be time-bound and subject to review.

Exceptions shall not be granted for activities that are illegal, that pose unacceptable risk to the Institute or external systems, or that violate CERT-In Directions or applicable laws.

29. POLICY VIOLATIONS AND ENFORCEMENT

Violations of this policy may result in one or more of the following, depending on the severity of the violation:

- Warning and security counselling;
- Temporary restriction or suspension of access to Institute IT resources;
- Disciplinary action as per the applicable Institute rules (for students, staff, and faculty separately);
- Legal action under applicable Indian laws (IT Act 2000, DPDP Act 2023, and other relevant statutes) where the violation constitutes a criminal offence.

The Institute shall ensure that enforcement remains fair, proportionate, and consistent with academic values. Users will be given an opportunity to explain circumstances before serious action is taken, except in cases requiring immediate containment of a security threat.

The Institute shall not be held responsible for any legal implication arising from actions of a user in violation of this policy.

30. FRAMEWORK ALIGNMENT

This policy has been developed and aligned with the following frameworks, regulations, and guidelines:

Framework / Regulation	Relevance
CERT-In Directions (April 2022 and subsequent advisories)	Mandatory compliance requirements for incident reporting, log retention, vulnerability management, and VAPT
Information Technology Act, 2000 (and amendments)	Legal framework for cybercrime, unauthorized access, and data security obligations in India
Digital Personal Data Protection (DPDP) Act, 2023	Personal data handling, privacy rights, and data protection obligations
ISO/IEC 27001:2022	International standard for Information Security Management Systems (ISMS) – provides governance and control framework
NIST Cybersecurity Framework (CSF 2.0)	Risk-based framework covering Identify, Protect, Detect, Respond, and Recover functions
CIS Controls v8	Prioritized set of cybersecurity controls and safeguards for effective cyber defense
Zero Trust Architecture Principles (NIST SP 800-207)	Progressive adoption of 'Never Trust, Always Verify' model for access security
OWASP Secure Coding Practices	Reference for secure web application and software development practices

31. POLICY REVIEW AND UPDATE

This policy shall be reviewed and updated periodically by the Institute in consultation with CIC, the Information Security Governance Committee, Academic Representatives, and Legal/Compliance authorities.

The policy may be updated based on:

- Emerging cyber threats and new attack vectors;
- CERT-In advisories, directions, and regulatory changes;
- Changes to Indian laws and regulations (IT Act, DPDP Act, etc.);
- Technological evolution and adoption of new platforms;
- Significant changes in institutional requirements or structure;
- Post-incident reviews and lessons learned.

The security policy shall be reviewed and updated at least annually, or as and when significant changes in the threat landscape or regulatory environment necessitate an update, subject to the Institute's own discretion. All revisions shall be finally approved by the competent authority.

32. CONCLUSION

IIT Kharagpur recognizes that cybersecurity in a large academic campus environment requires a balanced and pragmatic approach – one that protects critical infrastructure and institutional assets while preserving the openness, collaborative spirit, and flexibility essential to academic excellence and world-class research.

The Institute shall strive to:

- Protect critical infrastructure and institutional assets from evolving cyber threats;
- Preserve the openness necessary for academic excellence and research collaboration;
- Build and continuously improve cyber resilience;
- Foster a culture of cybersecurity awareness and shared responsibility across the Institute community;
- Continuously evolve its security posture in response to emerging threats and regulatory changes.

All members of the IIT Community, including students, faculty, staff, researchers, and visitors, share the responsibility of maintaining a secure, trusted, and resilient digital environment at IIT Kharagpur.
